

ISO 27001: Governance and Risk Management

Melvin Viado

100899671

Cybersecurity, Durham College

MGMT 1100: Business Process and Security Policy

Danny Aniag

November 2, 2025

Contents

Questions.....	3
Understanding ISO 27002:2005.....	3
Understanding Policy Development and Authorization	3
Understanding Information Security Officers	4
Understanding Risk Terms and Definitions	5
Understanding Insurance.....	6
References	7

Questions

Understanding ISO 27002:2005

The following questions are for the following statement in the textbook:

The introduction to ISO 27002:2005 includes this statement: “This International Standard may be regarded as a starting point for developing organization-specific guidelines. Not all of the controls and guidance in this code of practice may be applicable. Furthermore, additional controls and guidelines not included in this standard may be required.”

1. Explain how this statement relates to the concept of strategic alignment.

“Cybersecurity is a business discipline that exists to support business objectives, add value, and maintain compliance with externally imposed requirements.” (Santos, 2019). Strategic alignment involves a relationship between cybersecurity and the business. This statement relates to the concept of strategic alignment as additional controls and guidelines should be added to support business objectives, add value, and maintain compliance.

2. The risk assessment domain was included in the ISO 27002:2005 edition and then removed in ISO 27002:2013. Why do you think they made this change?

The risk assessment domain was removed in ISO 27002:2013 as the standards moved from directing risk assessment controls to instead guiding security controls for risk assessment (Boulanger). As the statement mentions, some controls may not be applicable or required, and risk assessment controls are served as a preference rather than a direct advisory. I think they removed risk assessment guidance from ISO 27002 in 2013 because risk assessment guidance was a subset of ISO 27005.

3. What are the major topics of ISO 27005

“ISO 27005 defines the high-level risk management approach recommended by ISO” (Santos, 2019). The major topics of ISO 27005 include risk assessment, treatment, acceptance, communication, monitoring, and review. ISO 27005 provides structured and comprehensive details in managing information security risk.

Understanding Policy Development and Authorization

The following questions are for the following statement in the textbook:

Three entrepreneurs got together and created a website design hosting company. They will be creating websites and social media sites for their customers, from simple "Hello World" pages to full-fledged e-commerce solutions. One entrepreneur is the technical guru, the second is the marketing genius, and the third is in charge of finances. They are equal partners. The entrepreneurs also have five web developers working for them as independent contractors on a per-project basis. Customers are requesting a copy of their security policies.

1. Explain the criteria they should use to develop their policies. Who should authorize the policies?

The criteria that they should use to develop their policies should include the “size and complexity of the organization, regulatory requirements, available expertise, and segregation of duties” (Santos, 2019). Directors and executive management are obligated to be responsible for and manage the company. Cybersecurity policies should be authorized by executive management who may be defined as owners, directors, or executive officers based on organizational requirements. Executive management should oversee the effectiveness of the cybersecurity policies and use methods to evaluate and report what the policy contains.

2. Should the policies apply to the independent contractors? Why or why not?

The scope of the cybersecurity policy extends to all functional areas including independent contractors unless explicitly excluded. Therefore, the policies should apply to the independent contractors because they often have access to sensitive data and systems as part of their organizational operations. Policies should extend to these contractors to ensure security controls and procedures are followed and to reduce the risk of data breaches or losing control of assets. Violation of policies should result in disciplinary actions that scales with the violation, which may include civil and criminal prosecution.

3. What type of documentation should they provide their customers?

The cybersecurity policy documentation should be provided to their customers, specifically including how they secure sensitive data, their incident response procedures, and how the security of independent contractors are managed. Additionally, user-level documentation derived from the cybersecurity which include the Acceptable User Policy, Acceptable Use Agreement, and Information Handling instructions should be provided. These documents support transparency and accountability of the organization and makes less severe the risk of the organizational reputation.

Understanding Information Security Officers

1. ISOs are in high demand. Using online job hunting sites (such as Monster.com, Dice.com, and TheLadders.com), research available positions in your geographic area.

A Security Operations Specialist position is available for Deighton Associates Ltd found in Whitby, Ontario. They are looking for someone that will play an important role in maintaining the security and operational integrity of their software development infrastructure. The job position mentions that this role is integral in supporting ongoing ISO 27001 compliance efforts and to improve their security posture. Ways this organization is looking to improve their security posture involves development of their security processes, policy development, documentation of evidence, and audit support.

2. Is there a common theme in the job descriptions?

Yes, the common theme for information security officer positions is to protect data, monitor systems, assess risk, assess vulnerabilities, maintain controls, and ensure compliance and documentation. Organizations are also looking for non-technical competencies such as business awareness, professionalism, collaboration, and analytical thinking skills. Lastly, organizations seek specific certifications, education, and experience that confirm competence that confirm one would fit the specified position.

3. What type of certifications, education, and experience are employers seeking?

For education, a bachelor's degree in information security or a related discipline is usually required, while advanced degrees can increase your qualifications but is not needed. For certifications, CCISO, CISSP, CISM, and other additional certifications can help confirm your skills and abilities in which an information security officer position would require. Lastly, organizations would seek multiple years of experience in information security roles or related work. They would seek experience in direct management, risk assessment, compliance, and incident response in this management level position.

Understanding Risk Terms and Definitions

1. Define each of the following terms: inherent risk, threat, threat source, vulnerability, likelihood, impact, and residual risk.

Inherent Risk: The level of risk prior to security measures being applied.

Threat: A natural, environmental, technical, or human-related aspect that may result in an unwanted cause or impact.

Threat Source: An intentional or unintentional exploitation or trigger of a vulnerability.

Vulnerability: A weakness in an information system, application, network, security procedure, internal control, or implementation that could be exploited or triggered by a threat source or subjected to misuse.

Likelihood: The probability a threat can exploit a vulnerability.

Impact: The extent of harm

Residual Risk: The level of risk after security measure are applied.

2. Provide examples of security measures designed to (a) deter a threat source, (b) prevent a threat source from being successful, and (c) detect a threat source.

Deterrent controls attempt to discourage individuals from causing an incident. Surveillance cameras, motion alarm systems, and security guards are physical controls that deter a threat source. Preventative controls attempt to prevent an incident from occurring. Security Awareness Training and Account Disablement Policy are controls to prevent a threat source from being successful. Detective controls attempt to detect errors and locate attacks against information systems that have already occurred. Log monitoring and security audits are examples of detective controls.

3. Explain risk avoidance and why that option is generally not chosen.

Risk avoidance are actions that eliminate or greatly modify processes associated with a risk. Risk management typically does not use risk avoidance, especially in important processes, because it misses business opportunities, reduces innovation, and raises costs without benefits. This is due to consideration of prior investment and analysis of the opportunity costs of the organization. Risk avoidance is good for evaluating new processes and products.

Understanding Insurance

1. What is cyber-insurance and what does it generally cover?

Cyber insurance is insurance that for cyber-related incidents such as data breaches. Cyber-insurance covers costs that insurance policies usually do not cover, including direct costs for data recovery, legal fees, and more. Cyber-insurance is another defensive layer that helps organizations manage evolving risks relating to information system operations.

2. Why would an organization purchase cyber-insurance?

Other than financial protection, organizations would purchase cyber-insurance to experience the benefits of business continuity and regulatory compliance. Business will be able to hold their operational stability even after loss of income or increases in expenses from incidents. Insurance policies also greatly assist in covering costs related to regulatory requirements involving breach notifications and data protection laws. In general, additional resources given from cyber-insurance can be greatly beneficial for organizations in terms of incident recovering and risk management.

3. What is the difference between first-party coverage and third-party coverage?

First-party coverage covers costs for damage to the data owned by the holder of the policy, or loss in income or business. Third-party coverage covers costs associated with liabilities a policyholder has for clients or governmental entities.

References

- Boulanger, P. (n.d.). *ISO 27002 2013 to 2022 mapping*. LevelBlue. <https://levelblue.com/blogs/security-essentials/iso-27002-2013-to-2022-mapping>
- Insurance, N., & Tela, E. (2024, November 22). *Understanding the importance of Cyber Insurance in the Digital age*. Northbridge Insurance. <https://www.northbridgeinsurance.ca/blog/understanding-the-importance-of-cyber-insurance-in-the-digital-age/>
- Job search | indeed. (n.d.). <https://www.indeed.com/>
- Michael Swanagan, C. (2025, October 6). *The 3 types of security controls (expert explains)*. PurpleSec. <https://purplesec.us/learn/security-controls/>
- Santos, O. (2019). *Developing cybersecurity programs and policies*. Pearson Education.